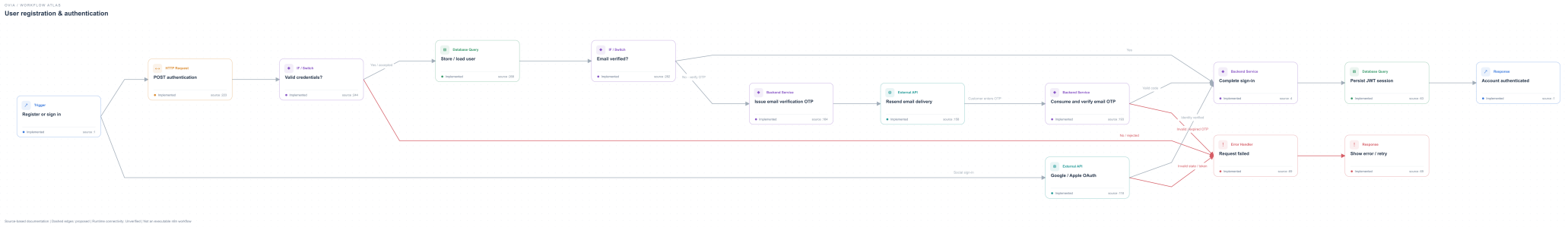
User registration & authentication

Architecture overview. Readable node and connection sheets follow.



User registration & authentication

Readable detail sheet 1/4. Node numbers and page references preserve every directed connection.

#01 / Trigger / Implemented

Register or sign in

Account authentication forms and verification experience.

src/components/auth-experience.tsx:1

Next -> #2 (p2); Social sign-in -> #14 (p5)

#02 / HTTP Request / Implemented

POST authentication

Registration and login share the dispatcher. Password, email and terms requirements differ.

src/app/api/v1/[[...path]]/route.ts:223

Next -> #3 (p2)

#03 / IF / Switch / Implemented

Valid credentials?

Zod validation, password policy, duplicate email checks and scrypt password verification.

src/app/api/v1/[[...path]]/route.ts:244

Yes / accepted -> #4 (p2); No / rejected -> #11 (p4)

#04 / Database Query / Implemented

Store / load user

users: id, email, passwordHash, verification and terms fields.

src/app/api/v1/[[...path]]/route.ts:268

Next -> #5 (p3)

User registration & authentication

Readable detail sheet 2/4. Node numbers and page references preserve every directed connection.

#05 / IF / Switch / Implemented

Email verified?

Unverified accounts receive an email OTP. Verified accounts proceed to completeSignIn.

src/app/api/v1/[[...path]]/route.ts:282

Yes -> #8 (p3); No - verify OTP -> #6 (p3)

#06 / Backend Service / Implemented

Issue email verification OTP

Generate and hash a one-time verification code with expiration and attempt limits.

src/server/recovery.ts:184

Next -> #7 (p3)

#07 / External API / Implemented

Resend email delivery

Email provider HTTP call; failures cannot be treated as successful delivery. Runtime configuration and connectivity are Unverified.

src/server/mail.ts:158

Customer enters OTP -> #13 (p5)

#08 / Backend Service / Implemented

Complete sign-in

Merge guest cart and account state, then create the session.

src/server/account-sign-in.ts:4

Next -> #9 (p4)

User registration & authentication

Readable detail sheet 3/4. Node numbers and page references preserve every directed connection.

#09 / Database Query / Implemented

Persist JWT session

HS256 JWT in HttpOnly cookie; hashed jti in sessions with userId and expiration.

src/server/auth.ts:63

Next -> #10 (p4)

#10 / Response / Implemented

Account authenticated

Successful sign-in returns safe user fields and navigates the customer account.

src/components/auth-experience.tsx:1

END: no outgoing connection

#11 / Error Handler / Implemented

Request failed

Validation, access, conflict or service errors are returned to the caller. Status and error shape depend on the specific route.

src/server/http.ts:69

Next -> #12 (p4)

#12 / Response / Implemented

Show error / retry

Failure end state. Caller receives the actual error; a retry may be offered by the UI.

src/server/http.ts:69

END: no outgoing connection

User registration & authentication

Readable detail sheet 4/4. Node numbers and page references preserve every directed connection.

#13 / Backend Service / Implemented

Consume and verify email OTP

Submitted code is compared with the hashed token, checked for expiry and attempt limits, then consumed.

src/server/recovery.ts:193

Valid code -> #8 (p3); Invalid / expired OTP -> #11 (p4)

#14 / External API / Implemented

Google / Apple OAuth

State and PKCE flow, code exchange, JWKS identity verification and resolveSocialUser. Runtime configuration and connectivity are Unverified.

src/server/social-auth.ts:118

Identity verified -> #8 (p3); Invalid state / token -> #11 (p4)

User registration & authentication

Complete directed connection register / no omitted success, failure or proposed edges

#01 Register or sign in -> #02 POST authentication | Next

#02 POST authentication -> #03 Valid credentials? | Next

#03 Valid credentials? -> #04 Store / load user | Yes / accepted

#04 Store / load user -> #05 Email verified? | Next

#06 Issue email verification OTP -> #07 Resend email delivery | Next

#08 Complete sign-in -> #09 Persist JWT session | Next

#09 Persist JWT session -> #10 Account authenticated | Next

#03 Valid credentials? -> #11 Request failed | No / rejected | FAILURE

#11 Request failed -> #12 Show error / retry | Next | FAILURE

#05 Email verified? -> #08 Complete sign-in | Yes

#05 Email verified? -> #06 Issue email verification OTP | No - verify OTP

#07 Resend email delivery -> #13 Consume and verify email OTP | Customer enters OTP

#13 Consume and verify email OTP -> #08 Complete sign-in | Valid code

#13 Consume and verify email OTP -> #11 Request failed | Invalid / expired OTP | FAILURE

#01 Register or sign in -> #14 Google / Apple OAuth | Social sign-in

#14 Google / Apple OAuth -> #08 Complete sign-in | Identity verified

#14 Google / Apple OAuth -> #11 Request failed | Invalid state / token | FAILURE

Note: Source implementation is documented; deployed configuration and provider connectivity are not verified.

Note: The OTP delivery and verification nodes apply only to unverified email accounts. The Yes branch below bypasses OTP. Google and Apple use a separate OAuth branch.